Google Cloud Platform · AegisAI

AI SECURITY & GOVERNANCE ASSURANCE SUITE

MANUAL OFICIAL DE USUARIO Y OPERACIONES

# Manual de Uso del Operador

Guía integral para la auditoría, evaluación de riesgos, monitoreo continuo y remediación de sistemas de IA generativa y agentes en Google Cloud.

OWASP AI-SVS v1.0 | ISO/IEC 42001:2023 (SGIA) | Google Cloud Vertex AI | Firestore aegis-ai-db | Zero-Trust & Dominios Autorizados

| | |
|---|---|
| **Identificador Documental:** | DOC-AEGIS-OPS-2026-V2 |
| **Público Objetivo:** | Auditores de IA, Arquitectos de Seguridad Cloud, Equipos de Cumplimiento y DevSecOps |
| **Autor / Arquitecto Líder:** | AegisAI Open Source Community & Core Security Engineering Team |
| **Base de Datos Dedicada:** | `aegis-ai-db` (Proyecto: your-gcp-project-id) |
| **Versión de Plataforma:** | AegisAI v2.0 Enterprise (Edición Metálica Google Cloud) |
| **Fecha de Liberación:** | 24 de Septiembre de 2026 |
| **Clasificación:** | Open Source / Public Community Release (Apache 2.0) |

# Indice de Contenido

1. **1. Introducción y Alcance Operativo** — Propósito de AegisAI y marco regulatorio dual.
2. **2. Acceso y Autenticación Segura** — Zero-Trust, Google Workspace OAuth y políticas de dominio.
3. **3. Navegación por el Dashboard Ejecutivo** — KPIs de madurez, filtros normativos y lista de sistemas.
4. **4. Flujo de Nueva Auditoría Manual** — Parametrización, niveles de evaluación (L1-L3) y manifiesto.
5. **5. Escáner en Vivo de Google Cloud** — Conexión con GCP (ADC/Service Account/Token), recolección de telemetría y auditoría automática.
6. **6. Análisis e Interpretación de Reportes Técnicos** — Puntos aprobados/fallidos, evidencia técnica, matriz RACI y plan de remediación.
7. **7. Ciclo de Vida de Remediación y Re-auditoría** — Proceso de corrección y generación del reporte 100% conforme.
8. **8. Catálogo de Marcos y Frameworks Personalizados** — Uso de marcos mexicanos (INAI, LFPC) y creación de estándares propios.

## 1. Introducción y Alcance Operativo

**AegisAI** es una plataforma corporativa desarrollada sobre Google Cloud diseñada para automatizar la auditoría técnica, la gobernanza algorítmica y la verificación de seguridad de modelos fundacionales (LLMs), arquitecturas RAG (Retrieval-Augmented Generation) y agentes autónomos.

La plataforma evalúa simultáneamente los dos estándares internacionales líderes:

- **OWASP AI-SVS v1.0 (AI Security Verification Standard):** Verificación técnica de 12 capítulos de ciberseguridad, incluyendo inyección de prompts, envenenamiento de datos, denegación de servicio por ventana de contexto y robo de modelos.
- **ISO/IEC 42001:2023 (Sistema de Gestión de IA - SGIA):** Cumplimiento de las Cláusulas 4 a 10 y los Controles del Anexo A (Políticas de IA, Análisis de Impacto Algorítmico, Supervisión Humana y Calidad de Datos).

> **Aislamiento de Base de Datos (aegis-ai-db)**
> A partir de la versión 2.0, AegisAI opera en una base de datos nombrada independiente ( `aegis-ai-db` ) desacoplada de la base por defecto del proyecto GCP, garantizando aislamiento estricto y gobernanza de datos para auditoría.

## 2. Acceso y Autenticación Segura

El acceso a AegisAI implementa una arquitectura **Zero-Trust** estricta basada en Google Cloud Identity y Firebase Authentication.




### Reglas de Acceso:

- Únicamente se admiten correos con dominio corporativo verificado ( `@example.com` ). Cualquier otro dominio es rechazado tanto en el cliente como en las reglas de seguridad de Firestore a nivel kernel de base de datos.
- Las sesiones no se persisten en almacenamiento local no seguro. Al cerrar el navegador o presionar **Cerrar Sesión**, los tokens se purgan inmediatamente.

## 3. Navegación por el Dashboard Ejecutivo

El Dashboard principal consolida en una sola pantalla el estado de salud de todos los sistemas de IA de la organización:

| COMPONENTE UI | FUNCIÓN Y COMPORTAMIENTO |
|---|---|
| **Tasa de Conformidad Global** | Gráfica de dona interactiva que muestra el porcentaje de sistemas conformes (calificación ≥ 80%) frente a sistemas que requieren remediación (< 80%). |
| **Top Inconformidades (Fallos)** | Gráfica de barras horizontales con los capítulos donde más controles han fallado, permitiendo priorizar las brechas de seguridad más críticas. |
| **Top Conformidades (Aprobados)** | Controles validados exitosamente que demuestran evidencia técnica sólida ante auditores externos. |
| **Selector de Normas (Pills)** | Filtra al instante las métricas entre: *Vista Global Consolidada*, *OWASP AI-SVS*, *ISO/IEC 42001*, *Vista Dual* o *Marcos Personalizados*. |
| **Botón '⚡ Cargar 5 Auditorías'** | Permite poblar la base de datos `aegis-ai-db` con 5 auditorías completas de ejemplo de Google Cloud para pruebas inmediatas. |

## 4. Flujo de Nueva Auditoría Manual

Para auditar un nuevo sistema de IA que aún no está desplegado o cuyo manifiesto se construyó manualmente:

1. Haz clic en el botón **+ Nueva Auditoría** en el encabezado del Dashboard.
2. Selecciona la norma aplicable: `OWASP AI-SVS` , `ISO/IEC 42001` , `Evaluación Dual` o un `Marco Personalizado` .
3. Define el **Nivel Objetivo**:
   - **L1 (Básico):** Aplicaciones internas sin datos sensibles ni impacto a usuarios finales.
   - **L2 (Enterprise / PaaS):** Aplicaciones corporativas con RAG, atención a clientes o datos confidenciales.

- **L3 (Crítico):** Sistemas autónomos financieros, médicos o con impacto en decisiones de vida o legales.



4. Ingresa el nombre del sistema, líder técnico responsable y la descripción técnica detallada (arquitectura, APIs, bases de datos vectoriales y controles de acceso).
5. Haz clic en **Ejecutar Auditoría con IA**. El motor Gemini analizará el sistema contra cada control y generará el veredicto en tiempo real.

## 5. Escáner en Vivo de Google Cloud

El módulo **GCP Live Scanner** permite conectar AegisAI a un proyecto real de Google Cloud mediante APIs de solo lectura para extraer la arquitectura sin intervención humana:

| MODO DE AUTENTICACIÓN | DESCRIPCIÓN Y CASO DE USO |
|---|---|
| `Application Default Credentials (ADC)` | Modo predeterminado cuando AegisAI se ejecuta en Cloud Run, GKE o Compute Engine con la identidad de la carga de trabajo (Workload Identity). |
| `Service Account JSON (En Memoria)` | Permite ingresar credenciales temporales que se procesan únicamente en la memoria RAM del servidor sin tocar el disco duro. |
| `Bearer Access Token` | Token temporal generado mediante `gcloud auth print-access-token` con vigencia máxima de 60 minutos. |
| `Modo Simulación / Demo` | Permite evaluar el escáner utilizando telemetría enterprise simulada de Google Cloud sin requerir un proyecto real. |

## 6. Análisis e Interpretación de Reportes Técnicos

Al hacer clic en cualquier sistema evaluado, se despliega el **Informe Técnico Completo**, el cual contiene:

- **Calificación Porcentual (0-100%):** Ponderación estricta de puntos aprobados sobre puntos aplicables.
- **Desglose por Capítulos:** Cada punto de control detalla el método de aprobación, la causa del fallo (si aplica), la evidencia técnica verificable y el plan de remediación.
- **Matriz RACI Oficial:** Asignación de responsabilidades para el CISO, AI Architect, Data Scientist y Compliance Officer.
- **Inmutabilidad Garantizada:** Cada informe cuenta con un ID criptográfico inmutable en `aegis-ai-db` que impide su alteración o eliminación arbitraria.